SPIKA TECH

Auditorías de código

Procedimiento de revisión de código y validación de seguridad para entornos de producción

TABLA DE CONTENIDO

1. Objetivos 3
2. Alcance 3
3. Revisión automática - GitHub Actions 3
4. Controlador de código seguro 3
5. Generación de informes 4
6. Registro y archivo 4
7. Revisiones periódicas 5

empresa innovadora de base tecnológica
reconocida por ANCES
INNOVATIVE SME
Valid until Jan 13th 2026
Funded by the European Union

1. Objetivos

El presente procedimiento tiene como objetivo definir las directrices para la realización de auditorías de código fuente en los proyectos de desarrollo de software de la organización, con el fin de garantizar la detección oportuna de vulnerabilidades, malas prácticas de programación y exposición de información sensible. Esta práctica forma parte del ciclo seguro de desarrollo.

2. Alcance

Este procedimiento aplica a todos los proyectos de desarrollo de software internos y externos, así como a cualquier código que se integre, mantenga o despliegue bajo la responsabilidad de la organización, sin importar su entorno de ejecución (on-premise, nube o híbrido).

3. Revisión automática - GitHub Actions

Como parte del flujo de integración continua, se utiliza **GitHub Actions** para aplicar auditorías automatizadas al código fuente en cada fase del desarrollo. Toda modificación de código (commits o pull requests) que se integre al repositorio deberá pasar por este sistema, que ejecuta:

- **Linting automático:** Verificación de estilo de código, buenas prácticas y convenciones.
- **Análisis estático de código:** Detección de errores comunes, uso indebido de estructuras o patrones peligrosos.
- **Ejecución de pruebas unitarias y de integración.**
- **Validación de ramas autorizadas:** Solo se permite la integración de código en ramas autorizadas como DEVELOPMENT, PRE-PRODUCTION o PRODUCTION tras validación exitosa del pipeline.

Este control automático ayuda a prevenir que código potencialmente inseguro alcance fases avanzadas del ciclo de desarrollo o entornos de producción.

4. Controlador de código seguro

Antes de desplegar cualquier versión de software al entorno de PRE-PRODUCTION O PRODUCTION, será obligatorio generar un informe de revisión de seguridad mediante el uso de la herramienta **“Spika Tech - Code Checker”**.

Esta herramienta realiza una auditoría automatizada sobre el código fuente e incluye los siguientes análisis:

- **Comprobación de dependencias vulnerables:** Verifica las bibliotecas importadas frente a bases de datos de vulnerabilidades conocidas.

contact@spikatech.com - www.spikatech.com

SPIKA TECH, S.L., with registered office at c/ Alcalá de Guadaira, nº 6, 6ºA Derecha, 28018 MADRID, with Tax Identification Code B87386900, registered in the Mercantile Register of Madrid, in volume 33.500, Folio 200, Page M-603059, Entry. 1, hereinafter THE OWNER.

- **Búsqueda de secretos expuestos**: Detecta contraseñas, claves API, tokens y otras credenciales sensibles en el código.

- **Detección de funciones inseguras**: Identifica el uso de funciones potencialmente peligrosas como eval() o exec().

- **Verificación del manejo de excepciones**: Asegura una gestión adecuada de errores sin exponer datos sensibles.

- **Revisión de datos sensibles**: Revisa la presencia de información sensible (como tokens de acceso o claves de servicios) y su correcta protección o cifrado.

5. Generación de informes

La herramienta Spika Tech - Code Checker genera un informe en formato PDF que debe ser revisado por el equipo responsable antes de proceder con el despliegue. El informe incluirá:

- Vulnerabilidades detectadas

- Credenciales expuestas

- Uso de funciones inseguras

- Malas prácticas en manejo de excepciones

- Presencia y gestión de datos sensibles

En caso de detectar hallazgos críticos, el código **no podrá ser desplegado** hasta que se realice la corrección, revisión y generación de un nuevo informe con resultado satisfactorio

6. Registro y archivo

Todos los informes generados deberán:

- Ser almacenados en un **repositorio interno seguro**, con acceso restringido al personal autorizado.

- Estar **versionados y vinculados** al commit o release correspondiente.

- Contener metadatos como: nombre del proyecto, fecha de análisis, responsable de la revisión, versión del código y observaciones.

La retención mínima de estos informes será de **3 años**, pudiendo ampliarse en función de requisitos regulatorios o contractuales. Estos registros constituyen **evidencias objetivas** ante auditorías internas o externas del SGSI.

contact@spikatech.com - www.spikatech.com

SPIKA TECH, S.L., with registered office at c/ Alcalá de Guadaira, nº 6, 6ºA Derecha, 28018 MADRID, with Tax Identification Code B87386900, registered in the Mercantile Register of Madrid, in volume 33.500, Folio 200, Page M-603059, Entry. 1, hereinafter THE OWNER.

7. Revisiones periódicas

El procedimiento de auditoría de código es revisado de forma **anual** o ante cambios importantes en las herramientas, metodologías o requisitos legales. La organización fomenta la mejora continua del proceso mediante:

- Actualización de reglas de análisis.
- Revisión de nuevas amenazas y patrones de ataque.
- Capacitación del equipo de desarrollo en prácticas de codificación segura.

SPIKA TECH, S.L., with registered office at c/ Alcalá de Guadaira, nº 6, 6ºA Derecha, 28018 MADRID, with Tax Identification Code B87386900, registered in the Mercantile Register of Madrid, in volume 33.500, Folio 200, Page M-603059, Entry. 1, hereinafter THE OWNER.